

Privacy Typing for Multi-Tenant Agent Interaction: A Federated, Center-Blind Auditor and an A2A Extension

Anonymous Author(s)

Abstract

Autonomous agents increasingly delegate work to one another across organizational boundaries, and protocols such as A2A now standardize how. These protocols carry no notion of whom a datum concerns or who may receive it, so the resulting leakage is hard to see: it happens on internal agent-to-agent channels and is often compositional, emerging from messages that are each individually benign. Centralized observability offers no remedy, because it must read the very content that sensitive, cross-organizational deployments will not expose.

We present a federated auditor that detects these leaks from desensitized metadata it can never invert to content, together with a privacy-typing extension to A2A that makes the leaks expressible in the first place. By separating the data subject, the owning principal, and the agent principal, the auditor flags cross-tenant disclosure, purpose violations, over-forwarding, and cross-tenant inference, all without reading a message. We prove the center-blind guarantee (the center learns $O(\log)$ bits per message) and characterize when inference becomes detectable, then test the system where it is easiest to fool ourselves: on a benchmark authored by a separate model it keeps perfect precision, and against a real LLM recipient we confirm that two benign fragments already expose a withheld attribute, a threat that grows with model capability. On its single-tenant projection, which is the deployable product, the auditor catches every internal-channel leak in AgentLeak’s 600 scenarios at 0.97 precision with zero content egress.

Keywords

multi-tenant agents, agent-to-agent protocols, privacy auditing, information-flow control, compositional inference, differential privacy

1 Introduction

Agents are starting to talk to *each other*. Protocols such as A2A (v1.0, Linux Foundation), MCP, and ACP let agents built by different teams discover capabilities and delegate work across organizational boundaries. As this fabric forms, a question with no answer today becomes urgent: *when my agent hands data to your agent, what did it just share, and was it allowed to?*

This is already a live privacy problem, not a hypothetical one. Production agents in regulated settings—healthcare schedulers, financial assistants, HR copilots—increasingly delegate to third-party agents, and a single over-shared identifier (an SSN, a diagnosis, an account number) crossing that organizational

boundary is a concrete privacy harm under regimes such as HIPAA and GDPR. Our aim is a deployable safeguard for exactly these real cross-organizational agent interactions: the system we build runs today, sees no raw content, and—as our in-the-wild study shows (§7)—catches current agents over-sharing regulated identifiers in 75% of realistic hand-offs.

Three things make this hard at once. The leakage is where it is least watched: inter-agent messages leak far more than final outputs, yet no current framework monitors the internal channel [8]. It is also compositional, arising from messages that are each individually benign even when every agent obeys its own policy [19]. And across organizations the parties do not trust one another: the other agent is the adversary, and no one will route raw content through a central observer, which is precisely what centralized observability (LangSmith, Langfuse) requires.

The protocols do not help. We verified against the A2A v1.0 specification that its data model (AgentCard, Task, Message, Part) has **no data-governance semantics**: no field marks whom a datum is about, who owns it, what it may be used for, or which agent may receive it. A2A provides free-form metadata, an extensions array, and a loosely-specified tenant field that routes but does not govern.

We close this gap. Our contributions:

- (1) **a2a.privacy/v1**, a privacy-typing extension carried in Part.metadata that types every shared datum (owner, subject, sensitivity, category, purpose, recipient set, hop limit, provenance id) and composes with unmodified A2A.
- (2) **A multi-tenant threat model and a center-blind auditor**. We separate the data subject, owning principal, and agent principal, and detect cross-tenant disclosure, purpose, hop/TTL, and *cross-tenant inference* from desensitized metadata the center cannot invert—the privacy-preserving counterpart to centralized observability.
- (3) **A2A-MT**, the first multi-tenant agent-privacy benchmark (parameterized families, realistic LLM-generated content), plus validation of the underlying engine on the external AgentLeak benchmark.

Setting every principal equal collapses the system to the **in-container** case—one organization auditing its own multi-agent app—so the research result and a practical product share one implementation (Figure 1).

2 Background and the governance gap

An A2A interaction is a sequence of Messages between agents; each carries Parts (text/data/file) and free-form metadata. The model has no field for ownership, sensitivity, purpose, or recipient restriction; privacy is delegated to “external access control” that, across tenants, does not exist. We add the missing layer inside A2A’s extension mechanism so it composes with deployed agents,

This work is licensed under the Creative Commons Attribution 4.0 International License. To view a copy of this license visit <https://creativecommons.org/licenses/by/4.0/> or send a letter to Creative Commons, PO Box 1866, Mountain View, CA 94042, USA.

Proceedings on Privacy Enhancing Technologies 2027(2), 1–7

© 2027 Copyright held by the owner/author(s).

<https://doi.org/XXXXXXX.XXXXXXX>



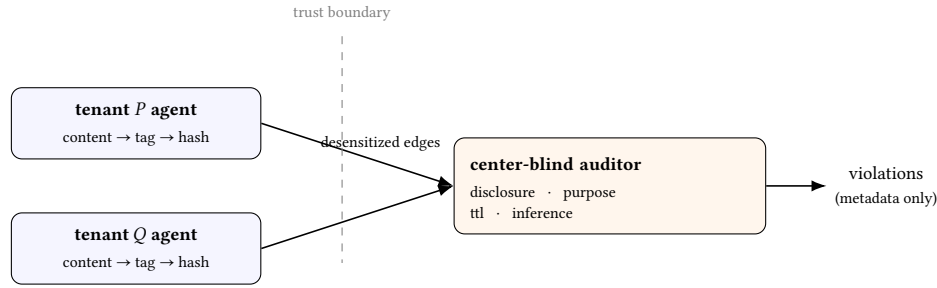


Figure 1: Federated, center-blind architecture. Inside each agent the raw content is tagged and hashed locally; only desensitized edges (a one-way hash plus a2a.privacy/v1 labels) cross the trust boundary. The center detects cross-tenant violations over this metadata graph, never seeing raw content (Lemma 5.1).

and audit it with a *federated* architecture: each agent desensitizes locally; a central auditor reasons over a graph of metadata it can never invert to content.

3 Threat model

Principals. A single identifier must not conflate three roles: the **data subject** (whom a Part is about), the **owning principal** (who controls the datum and the originating agent), and the **agent principal** (an agent’s AgentCard identity). Governance is defined over principals, not agents: a datum owned by P may reach an agent of Q only if Q is an allowed recipient for P ’s stated purpose.

Adversary. We consider a receiving or forwarding agent of a different tenant with three capabilities: (A1) it reads every Part routed to it and may *infer* beyond what is stated; (A2) it may *paraphrase, split, or re-route* what it forwards; and (A3) a *dishonest sender* may mislabel its own Parts (suppress tags or forge a subject id), since labels are produced locally. The adversary controls neither the A2A transport nor other tenants’ processes.

Trust assumptions (software baseline). (T1) *center-blind*: the auditor detects from desensitized metadata and never sees raw Part content, and no tenant reveals content to it or to peers; (T2) *honest-but-curious peers* for the disclosure, purpose, and TTL detectors—agents route truthfully but try to learn more than authorized; (T3) *A2A transport is given*—we annotate and audit, not replace. Under T1–T3 the design defeats A1 and A2 (wording and routing attacks) by construction, because the detectors key on labels and principals, not on text (§7); A3 is the residual the baseline does not close.

Closing A3 with forced-embed attestation. We remove the honest-labeler assumption with a downloaded, build-pinned component. The labeler and auditor ship as a fixed build B whose signing key k_B is confined to B ; a report is $R = (\mathcal{E}, \sigma)$ with $\sigma = \text{Sign}_{k_B}(H(\mathcal{E}))$ over the center-view edge set $\mathcal{E}$, and the center accepts R only if it verifies under B ’s published fingerprint.

PROPOSITION 3.1 (ATTESTATION SOUNDNESS). *If the signature scheme is EUF-CMA-secure and k_B is confined to B , then every report the center accepts equals B ’s output on the sender’s actual inputs, except with negligible probability. Hence a modified labeler that suppresses a tag or forges a subject id yields a report signed by an untrusted build (wrong fingerprint) and is rejected, and content*

tampering changes $H(\mathcal{E})$ and fails verification. The residual adversary is confined to (i) exfiltrating k_B from B —the case a hardware root of trust (TEE) closes—and (ii) sub-threshold leakage: disclosing strictly less than the detection threshold, which no metadata-only auditor can observe because nothing crosses to observe.

PROOF SKETCH. Acceptance requires a valid σ under B ’s fingerprint. Producing one for an $\mathcal{E}$ that B did not emit requires forging a signature (contradicting EUF-CMA) or obtaining k_B (excluded unless B is broken). Under-tagging and forgery both require running a labeler other than B , whose reports carry no valid σ ; tampering after signing changes $H(\mathcal{E})$. What remains is not a detection gap but an information gap: a sender that never emits the datum, or emits fewer than k^* converging fragments (Prop. 5.2), leaves nothing the center could key on. Canonical owner-derived subject ids (canonical_subject) make aliasing impossible without abandoning the attested derivation, collapsing A3’s forgery variant into case (i). $\square$

This is the guarantee the evasion study (§7, Table 1) exercises empirically.

4 The a2a.privacy/v1 extension

The three roles of the threat model become fields the protocol can carry. Each privacy-relevant Part carries a label stored under the "a2a.privacy/v1" key of Part.metadata: a PrivacyLabel with fields subject, owner, sensitivity $\in[0,5]$, category[], inferred_categories[], purpose[], allowed_recipients[], ttl_hops, and provenance_id. Identifiers are opaque (subject:alice, tenant:hospital)—governance metadata, never content. An AgentClearance (an AgentCard declaration) states the purposes an agent is cleared for, so cross-tenant rules are checkable from public metadata. Two fields are central to the results: **inferred_categories** is computed *locally* (the local auditor sees content; “near the oncology center” $\rightarrow$ health) and only the tag travels—the signal the inference detector accumulates without the center reading content; **provenance_id** is a stable datum identity assigned by the origin and preserved by forwarders even when they re-word the data, so hop/TTL tracking follows a datum across paraphrasing (a content hash breaks the moment a relay rephrases).

5 The center-blind auditor and detectors

These labels are exactly what the auditor reads, and the content is exactly what it does not. The auditor desensitizes each labeled Part into a center-view edge carrying a one-way content hash, the principals, and the label—no raw text (Figure 2). It asserts this invariant on its own output: a content token may appear in the center view only if it is a declared label value or a schema field name; any other token is a leak.

LEMMA 5.1 (BOUNDED CONTENT LEAKAGE). *Let a message M (with content entropy $H(M)$) produce center-view $V = (H(M), \ell)$, where H is a hash modeled as a random oracle and $\ell \in \mathcal{L}$ is the categorical label (category, sensitivity, taint tags, opaque principal/subject ids). Then the center’s information about M satisfies $I(M; V) \leq \log_2 |\mathcal{L}|$, a constant independent of $|M|$. Hence for $H(M) \gg \log_2 |\mathcal{L}|$ the center cannot reconstruct M .*

PROOF. $I(M; V) = I(M; H(M)) + I(M; \ell \mid H(M))$. Under the random-oracle model $H(M)$ is a uniformly random value revealing nothing of M beyond equality tests, so $I(M; H(M)) = 0$. The second term is at most $H(\ell) \leq \log_2 |\mathcal{L}|$. With $|\mathcal{L}|$ the product of the (small) label domains — e.g. a handful of categories $\times$ six sensitivity levels — this is $O(\log)$ bits per Part, independent of $|M|$; reconstructing M requires $H(M)$ bits, so it is infeasible. $\square$

This is the formal content of “center-blind”: the auditor operates on a metadata graph carrying $O(\log)$ bits per message, not a transcript. Four detectors run over this graph:

- (1) **Cross-tenant disclosure:** sensitive data ($\geq \tau$) reaches a principal that neither owns it nor is an allowed recipient.
- (2) **Purpose limitation:** data reaches an agent whose clearance purposes are disjoint from the data’s permitted purposes.
- (3) **Hop/TTL:** a datum (tracked by provenance_id) is relayed more than `ttn_hops` times; robust to a forwarder re-wording content.
- (4) **Cross-tenant inference:** no single edge is a disclosure, but a recipient principal accumulates converging inferred_categories fragments about one subject, letting it infer a sensitive category it was never authorized for (Figure 3); we ground this in the bound below.

A formal inference-gain bound. We model what a recipient infers about a subject’s sensitive attribute $A \in \{0, 1\}$ from k converging fragments $f_1, \dots, f_k$, with prior $p_0 = P(A=1)$ and odds $O_0 = p_0/(1 - p_0)$.

ASSUMPTION 1 (CONDITIONAL INDEPENDENCE). *Given A , the fragments are independent, each with likelihood ratio $\lambda_i = \frac{P(f_i|A=1)}{P(f_i|A=0)} \geq 1$; write λ for a common lower bound $\lambda_i \geq \lambda > 1$.*

PROPOSITION 5.2. *Under Assumption 1 the posterior odds are $O_k = O_0 \prod_i \lambda_i$, the posterior is $P(A \mid f_{1:k}) = O_k/(1 + O_k)$, and the inference gain $g(k) = P(A \mid f_{1:k}) - p_0$ is strictly increasing in k . With uniform λ , the detector (fires iff $g(k) \geq \delta$) fires exactly for $k \geq k^* = \lceil \log_\lambda (O_\delta/O_0) \rceil$, where $O_\delta = (p_0 + \delta)/(1 - p_0 - \delta)$.*

PROOF. By Bayes in odds form, $O_k = O_0 \prod_i \lambda_i$; since each $\lambda_i > 1$, O_k is strictly increasing in k , and $x \mapsto x/(1 + x)$ is strictly increasing, so g is strictly increasing. With uniform λ , $g(k) \geq \delta \iff P(A \mid f_{1:k}) \geq p_0 + \delta \iff O_k \geq O_\delta \iff O_0 \lambda^k \geq O_\delta \iff k \geq \log_\lambda (O_\delta/O_0)$; integrality gives the ceiling. $\square$

For defaults $(p_0, \lambda, \delta) = (0.1, 3, 0.3)$, $k^* = 2$: one hint never fires, two converging fragments do (posterior 0.50, gain 0.40), replacing the heuristic $1 - 2^{-k}$ with a calibrated quantity and a closed-form bound (Figure 4); deployments tune (p_0, λ, δ) and may set λ_i from the tagger’s hint specificity (so one high- λ fragment can suffice). On the assumption: real fragments are correlated, so Assumption 1 is an approximation — positively-correlated (redundant) hints make the true joint ratio smaller than $\prod \lambda_i$, so the model can over-credit evidence; empirically the detector nonetheless under-fires relative to a real LLM recipient, because tagger coverage, not the bound, is the binding constraint. The bound is thus a calibrated design tool, not a tight guarantee.

6 The A2A-MT benchmark

No multi-tenant agent-privacy benchmark exists—AgentLeak and Sum-Leaks are single-tenant (the vault belongs to one system; the boundary is system→output). A2A-MT supplies labeled multi-tenant A2A interactions whose boundary is *between* agents. A curated *calendar-negotiation* family (two people’s scheduling agents must reveal availability without leaking *why* a slot is blocked) instantiates all four violation types; parameterized families (group-assistant, marketplace-delegation, cross-tenant aggregation, plus disclosure, purpose, TTL, and inference sweeps with near-miss clean controls) give 48 labeled scenarios, ground truth set by template intent. An LLM fills each Part with realistic text matching its label (labels remain the ground truth), exported as a shareable artifact.

7 Evaluation

We ask whether the auditor detects multi-tenant leaks accurately and without seeing content; how it fares against the tools a practitioner would actually deploy; whether the result survives once we stop grading our own work; and whether the compositional threat it targets is real.

7.1 Detection and center-blindness

Over all 48 A2A-MT scenarios, $P/R/F1 = 1.0$ (TP= 18, FP= 0, TN= 30, FN= 0) with full per-type coverage (disclosure, purpose, TTL, inference), and no over-firing on single-hint clean controls. Zero raw Part content reaches the center on every scenario; the only content-derived value is a one-way hash.

7.2 Realistic content

Re-auditing the LLM-generated export (non-templated text) holds $P/R/F1 = 1.0$, 0 raw leaks: the detectors key on labels, not wording. Generating realistic content also exposed two correctness issues that hand-written tests hid (TTL fragility to paraphrasing, fixed by provenance_id; an invariant false-positive on prose tokens coinciding with label/schema tokens, fixed by excluding them), a benefit of scaling.

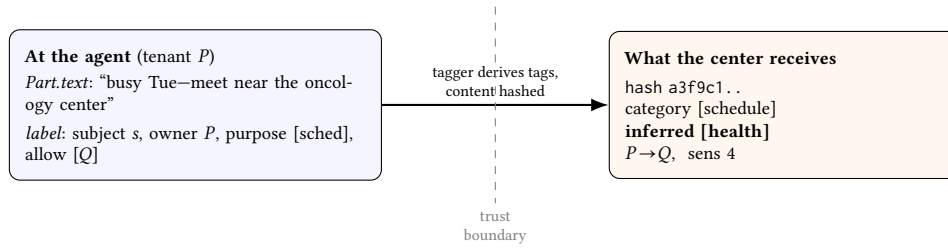


Figure 2: Desensitization at the edge. The local tagger turns a benign-looking message into governance tags (here it infers health from a scheduling note) and the content is hashed; only the right-hand edge—no text—crosses the trust boundary to the center. Recovering the message from it is infeasible (Lemma 5.1).

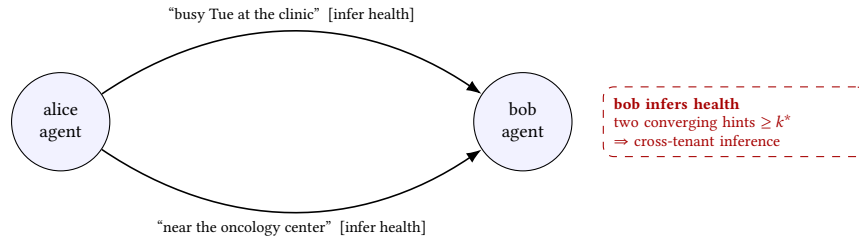


Figure 3: Cross-tenant inference. Neither scheduling message leaks a sensitive value, and bob is an allowed recipient of both; but the two hints converge on the same subject, and their accumulated evidence crosses the detection threshold (Prop. 5.2)—flagged from the labels alone, no content read.

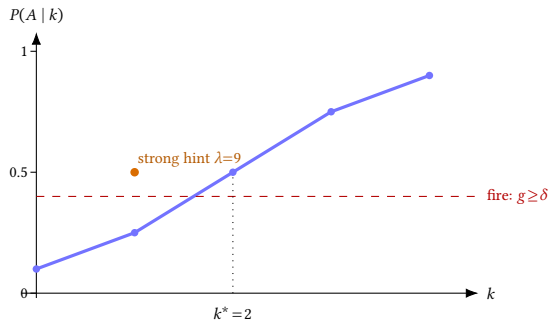


Figure 4: The inference threshold. Under uniform evidence ($p_0=0.1$, $\lambda=3$, $\delta=0.3$) the posterior crosses the fire line at $k^*=2$: one hint is tolerated, two converge. A single high-specificity hint ($\lambda=9$, from the tagger) already clears it.

7.3 Adaptive evasion, and closing the gap

An adversary that knows the inference detector is tested across evasions (Table 1). The design resists attacks on *wording and routing*; it is evaded only by a dishonest *local* labeler (suppressing tags or forging subject ids)—the trust assumption removed by forced-embed attestation and canonical owner-issued subject ids. Sub-threshold leakage evades only by leaking strictly less. We *implement* this defense: the auditor+tagger ship as a build-pinned component whose key is held only by the unmodified binary, and the center accepts a report only from a trusted build fingerprint. Under-tagging and forgery require modifying the labeler, so the

report is signed by an untrusted build and is **rejected**; tampering is caught by an edges-hash mismatch; canonical owner-derived subject ids (canonical_subject) make aliasing impossible without abandoning the attested derivation. The evasions become detected non-compliance, leaving only key compromise (the TEE regime) as residual—the guarantee stated formally in Prop. 3.1 (§3).

7.4 Metadata privacy under differential privacy

Beyond hiding content, we harden the metadata: identity-bearing fields are pseudonymized with a per-audit shared salt (cross-tenant comparisons hold in pseudonym space; the center learns no real identity) and sensitivity is DP-noised, while categories are kept structurally. Pseudonymization is lossless ($P/R/F1 = 1.0$); with DP, $F1 = 0.99/0.97/0.96$ at $\epsilon = 3/1/0.5$, recall falling only for disclosure decisions whose sensitivity noises across the floor, with zero raw content at every ϵ .

7.5 Comparison with real baselines

Against the two detectors a practitioner would actually reach for (Table 2, 8 realistic scenarios spanning PII disclosure, no-PII inference, and authorized sharing): *structurally*, both baselines must ingest content while ours ingests none, the disqualifier for regulated, cross-tenant deployments, independent of accuracy. *On accuracy*, the DLP scanner is blind to no-PII inference (0% recall) and over-flags authorized cross-boundary sharing; a single-shot policy-aware LLM-judge is unreliable on compositional inference across messages (0%, $F1 = 0.57$). Ours reaches full detection at zero content, the LLM tagger lifting the honest lexical floor $0.89 \rightarrow 1.0$.

Evasion strategy	Result
Paraphrase each fragment	resisted (tag-based, not text)
Split across recipient’s agents	resisted (grouped by principal)
Partial under-tag (≥ 2 tagged)	resisted
Sub-threshold (leak 1 fragment)	evades, but leaks less
Under-tag (1 of 3)	evades $\rightarrow$ needs attestation
Subject-id forgery	evades $\rightarrow$ needs canonical ids

Table 1: Adaptive evasion vs. the inference detector.

Detector	F1	inference rec.	content $\rightarrow$ center
DLP / PII scanner (sees content)	0.67	0%	439 ch
LLM-judge, policy-aware (reads all)	0.57	0%	439 ch
Ours — lexical tagger (blind)	0.89	50%	0
Ours — LLM tagger (blind)	1.00	100%	0

Table 2: Ours vs. real baselines on realistic scenarios.

7.6 The local tagger

The inference detector accumulates `inferred_categories`; in a real deployment these must be *produced* from content, not hand-set. A local tagger (lexical, zero-dependency, optional LLM backend) emits only tags—content never leaves the agent. On a labeled set with paraphrased cases, the lexical backend recovers explicit (sensitive) category at $P/R/F1 = 1.0$ and `inferred_categories` at $P = 1.0, R = 0.78$; the **LLM backend (gpt-4o-mini)** lifts **inferred-category recall** $0.78 \rightarrow 1.0$ (the misses are novel paraphrases like “the place where they treat tumors”). `AuditSession.observe` wires it in so a deployer supplies only text plus policy. Tagger recall is exactly the residual surface identified above (an adversarial sender can under-tag), which attestation closes.

7.7 External validation on AgentLeak

The multi-tenant auditor reuses a federated engine we validate on the external **AgentLeak** benchmark. Driving AgentLeak’s own 600 multi-agent scenarios through an LLM to produce real inter-agent traces and labeling leakage by AgentLeak’s rule, the auditor detects **100% of internal-channel leaks at 0.972 precision with zero raw vault content reaching the center** (82.5% internal-channel leak rate, matching AgentLeak). On a labeled 33-scenario set the engine holds $P/R/F1 = 1.0$, and under the full six-layer desensitizer plus DP it holds $F1 \approx 0.97$ at $\varepsilon \in [0.5, 3]$ with zero raw leakage, the privacy-utility result the multi-tenant typing builds on.

7.8 Agents in the wild

Away from any labeled benchmark, we measure how real agents behave: 12 realistic multi-agent workflows across 7 domains, each holding a sensitive record, where a coordinator (real gpt-4o-mini) is asked to delegate to an *external* specialist, with no engineered leaks, run $5 \times$ each (60 trials). The agent included the subject’s sensitive identifiers (SSN, MRN, account/card numbers, diagnoses) in the cross-boundary hand-off in $45/60 = 75\%$ of trials (95% Wilson

CI [63%, 84%]), and every hand-off to the different-purpose external party was a purpose violation (60/60, structural). The center-blind auditor flagged all with **zero raw content reaching the center**. Over-sharing concentrates where it is most sensitive: finance, healthcare, and legal disclosed in **100%** of trials, HR/support $\approx 50\%$, education 0%. This is the deployment-measurement counterpart to AgentLeak on the multi-tenant setting: left to their own judgment, current agents routinely over-share a subject’s identifiers across organizational boundaries, and the auditor catches it without seeing the data.

7.9 An author-independent benchmark

Our 48-scenario benchmark scores 1.0, but we wrote both the detectors and the scenarios. To de-bias it, an LLM (*not* the detector author) generates diverse scenarios with its own intended labels and we score our auditor against them. Across held-out runs (≈ 20 scenarios each), **precision is 1.0 (the architecture never over-fires) but recall is only ≈ 0.31 (lexical) / 0.38 (LLM tagger)**, far below the self-authored 1.0. The misses are dominated by tagger/taxonomy coverage: we broaden the sensitive set from health/finance/legal to ten configurable classes (+location, employment, education, behavioral, credentials, biometric, demographic), which raises recall, but open-world sensitive content remains the bottleneck; the author also states inferences explicitly and labels some borderline cases as leaks. Recall here is bounded by the tagger, an orthogonal and improvable component, not the auditor: every violation the architecture reports is real. The self-authored 1.0 measures the detectors given correct labels; the held-out setting measures the end-to-end pipeline on open-world content.

7.10 Is the inference threat real?

Our detector fires at $k^* = 2$ hints, but is that where real inferability begins? We have an independent LLM play the recipient and infer the subject’s withheld attribute from the K benign fragments it received ($K = 1, 2, 3$), scaled to **16 sensitive attributes** across health, finance, employment, legal, and behavioral domains

(5 trials each). *The threat is real, and for a frontier recipient it begins below our threshold:* Claude Opus 4.8 infers the withheld attribute from two benign fragments in **100% (16/16)** of attributes and from a *single* fragment in **81% (13/16)**. Weaker recipients need more evidence—an earlier study found gpt-4o-mini and gpt-4o inferring from two fragments in 3/4 and 4/4 of a smaller set—so the compositional threat grows as agents improve (per-model results across an open-weight size ladder are released with the artifact). *This makes our detector a conservative, no-false-alarm lower bound:* it stays silent at $K = 1$, yet a strong recipient already infers there; every disagreement is an under-fire, and we never fire where the recipient cannot infer. Hence detection must flag the metadata pattern, not try to out-infer the adversary. The threshold $k^* = 2$ with uniform evidence is conservative: real inference sometimes needs one high-specificity hint, which the Bayesian model of §5 accommodates via a per-fragment λ ; wiring λ to hint specificity catches single strong hints without over-firing.

8 Discussion

Center-blind detection works because the risks it targets are visible in the metadata graph (principals, categories, inferred-category tags, provenance), all of which the local side can emit without revealing content. The same observation explains why the system is at once a research result and a product: set every owning principal equal and the multi-tenant model collapses to the in-container case, where the identical detectors flag a sensitive datum crossing to an agent or tool it should not reach, still without shipping content anywhere.

The honest limits lie in coverage and in trust. Recall is bounded not by the auditor but by the tagger that feeds it: on author-independent scenarios precision stays perfect while recall trails, because open-world sensitive content outruns any fixed taxonomy. The inference bound assumes conditionally independent fragments, which real, correlated hints only approximate. And two adversaries remain open: a peer that both paraphrases *and* keeps every recipient below the convergence threshold, and a colluding sender–recipient pair that suppresses a shared datum—the residual that only a hardware root of trust (the TEE backend our attestation admits) fully closes.

9 Related work

Privacy leakage in LLM-agent systems. AgentLeak [8] and Sum-Leaks [19] measure and mitigate *single-tenant* compositional leakage; privacy-theory work for agents [2, 22] analyzes when local privacy fails to compose. LLMs also memorize and regurgitate training data [3, 4]. We lift the setting to *multi-tenant* and supply a deployable, center-blind detector rather than a measurement or a theory.

Agent communication protocols. A2A [13], MCP [1], and related standards define agent interoperability but no data governance; comparative security analyses [11, 14] flag exactly this gap, which we fill inside A2A’s extension mechanism.

Information-flow control and taint tracking. Our detectors are a lightweight, semantic information-flow analysis: the lattice model [5] and language-based IFC [20] formalize where data may flow, and dynamic taint tracking [9] enforces it at runtime. We

adapt these to opaque LLM agents over metadata (not program variables), adding purpose and cross-tenant semantics and *compositional inference*, which classical IFC does not model. Purpose- and recipient-limitation follow the norm of contextual integrity [18].

Data-loss prevention. DLP / PII scanners (e.g. Presidio [17]) match sensitive patterns in content; they see raw data, have no policy/purpose semantics, and are blind to no-PII inference (§7). We are center-blind and compositional.

Anonymization and differential privacy. k -anonymity [21] and ℓ -diversity [15] motivate our structural domain generalization; differential privacy [6, 7] and local DP [10] underlie our metadata hardening (§7). Unlike these, our object is *detection* of a composed leak, not release of a sanitized dataset.

Federated and secure computation. The federated split follows federated learning’s keep-data-local principle [16]; stronger guarantees are available via secure computation [23] and trusted execution, which our attestation layer (§7) plugs into. We target a deployable software baseline with a TEE upgrade path.

Observability. LangSmith and Langfuse [12] trace agent runs but must ingest raw prompts and outputs, the disqualifier for regulated, cross-tenant deployments and the one property our design structurally avoids.

Ethical Considerations

This work involves no human subjects and required no IRB review. Every scenario is synthetic: the A2A-MT benchmark and the in-the-wild study use LLM-generated content populated with fictional identifiers (invented names and format-valid but non-real SSNs, MRNs, and account numbers), and the external validation runs on the already-public AgentLeak benchmark. No real personal data is collected, stored, or transmitted. The artifact is defensive by construction and center-blind in operation: it detects privacy violations from desensitized metadata and, by design, no raw content reaches the central component even in deployment. We considered dual-use. Our threat model and inference detector describe how compositional leakage arises, but that same analysis is what a defender needs, and we disclose no attack beyond what AgentLeak and Sum-Leaks already document. No component met the threshold for an external ethics panel; we are glad to clarify any concern with the program committee.

Open Science

We are committed to open science. The full system—the a2a.privacy/v1 extension, the center-blind auditor and its four detectors, the local tagger, the attestation layer—and the A2A-MT benchmark generator are implemented and will be released under an open-source license upon publication, together with scripts that reproduce every quantitative result in Section 7. For double-blind review we provide an anonymized snapshot at <https://anonymous.4open.science/r/a2a-mt-audit> with identifying information removed. The benchmark is exported as a versioned, shareable artifact so results are reproducible independently of our implementation, and we intend to submit it to the PoPETS artifact review.

AI Use

AI-based tools were used both as part of our research methodology and in preparing this manuscript; we disclose both. *Methodology (described in the paper)*: the local tagger optionally uses an LLM backend (gpt-4o-mini) to derive privacy tags (§7); the A2A-MT benchmark and the author-independent held-out set are populated and authored by LLMs; and the threat-validation experiments use LLMs (gpt-4o-mini, gpt-4o, and Claude Opus 4.8) as the inferring recipient. These uses are integral to the contribution and are detailed in the referenced sections. *Writing*: the authors used generative AI-based tools to revise text, improve flow, correct typos and awkward phrasing, and assist with pre-submission review and related-work search. We have manually verified and take full responsibility for the accuracy, originality, and integrity of all content—including every citation—and of the output of all AI-based tools.

References

- [1] Anthropic. 2024. Model Context Protocol Specification.
- [2] Sadia Asif and Mohammad Mohammadi Amiri. 2026. Information-Theoretic Privacy Control for Sequential Multi-Agent LLM Systems. arXiv:2603.05520.
- [3] Nicholas Carlini, Daphne Ippolito, Matthew Jagielski, Katherine Lee, Florian Tramèr, and Chiyuan Zhang. 2023. Quantifying Memorization Across Neural Language Models. In *International Conference on Learning Representations (ICLR)*.
- [4] Nicholas Carlini, Florian Tramèr, Eric Wallace, Matthew Jagielski, et al. 2021. Extracting Training Data from Large Language Models. In *USENIX Security Symposium*.
- [5] Dorothy E. Denning. 1976. A Lattice Model of Secure Information Flow. *Commun. ACM* 19, 5 (1976).
- [6] Cynthia Dwork, Frank McSherry, Kobbi Nissim, and Adam Smith. 2006. Calibrating Noise to Sensitivity in Private Data Analysis. In *Theory of Cryptography Conference (TCC)*.
- [7] Cynthia Dwork and Aaron Roth. 2014. The Algorithmic Foundations of Differential Privacy. *Foundations and Trends in Theoretical Computer Science* 9, 3–4 (2014).
- [8] Faouzi El Yagoubi, Godwin Badu-Marfo, and Ranwa Al Mallah. 2026. AgentLeak: A Benchmark for Internal-Channel Privacy Leakage in Multi-Agent LLM Systems. arXiv:2602.11510.
- [9] William Enck, Peter Gilbert, Byung-Gon Chun, Landon P. Cox, Jaeyeon Jung, Patrick McDaniel, and Anmol N. Sheth. 2010. TaintDroid: An Information-Flow Tracking System for Realtime Privacy Monitoring on Smartphones. In *USENIX Symposium on Operating Systems Design and Implementation (OSDI)*.
- [10] Ulfar Erlingsson, Vasyl Pihur, and Aleksandra Korolova. 2014. RAPPOR: Randomized Aggregatable Privacy-Preserving Ordinal Response. In *ACM Conference on Computer and Communications Security (CCS)*.
- [11] Mohamed Amine Ferrag, Norbert Tihanyi, Djallel Hamouda, Leandros Maglaras, Abderrahmane Lakas, and Merouane Debbah. 2025. From Prompt Injections to Protocol Exploits: Threats in LLM-Powered AI Agent Workflows. arXiv:2506.23260.
- [12] LangChain and Langfuse. 2024. LangSmith and Langfuse: LLM Application Observability Platforms. Software.
- [13] Linux Foundation. [n. d.]. Agent2Agent (A2A) Protocol Specification, v1.0. <https://a2a-protocol.org>.
- [14] Yedidel Louck, Ariel Stulman, and Amit Dvir. 2025. Security Analysis of Agentic AI Communication Protocols: A Comparative Evaluation. arXiv:2511.03841.
- [15] Ashwin Machanavajjhala, Daniel Kifer, Johannes Gehrke, and Muthuramakrishnan Venkatasubramanian. 2006. ϵ -Diversity: Privacy Beyond k -Anonymity. In *IEEE International Conference on Data Engineering (ICDE)*.
- [16] Brendan McMahan, Eider Moore, Daniel Ramage, Seth Hampson, and Blaise Agüera y Arcas. 2017. Communication-Efficient Learning of Deep Networks from Decentralized Data. In *Artificial Intelligence and Statistics (AISTATS)*.
- [17] Microsoft. [n. d.]. Presidio: Data Protection and De-identification SDK. <https://github.com/microsoft/presidio>.
- [18] Helen Nissenbaum. 2004. Privacy as Contextual Integrity. *Washington Law Review* 79 (2004).
- [19] Vaidehi Patil, Elias Stengel-Eskin, and Mohit Bansal. 2025. The Sum Leaks More Than Its Parts: Compositional Privacy Risks and Mitigations in Multi-Agent Collaboration. arXiv:2509.14284.
- [20] Andrei Sabelfeld and Andrew C. Myers. 2003. Language-Based Information-Flow Security. *IEEE Journal on Selected Areas in Communications* 21, 1 (2003).
- [21] Latanya Sweeney. 2002. k -Anonymity: A Model for Protecting Privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems* 10, 5 (2002).
- [22] Ya-Ting Yang and Quanyan Zhu. 2026. Differential Privacy in Generative AI Agents: Analysis and Optimal Tradeoffs. arXiv:2603.17902.
- [23] Andrew C. Yao. 1982. Protocols for Secure Computations. In *IEEE Symposium on Foundations of Computer Science (FOCS)*.